

Manual 42 — Canada Privacy Controlled Implementation

****Controlled baseline:**** PIPEDA remains the federal private-sector privacy baseline, with provincial substantially-similar/private-sector laws, sector rules, and Office of the Privacy Commissioner guidance/findings treated as distinct source layers.

****Boundary:**** applicability depends on organization, province, activity, sector, employment context, and interprovincial/international facts; do not represent one federal rule as universally controlling all Canadian processing.

****Release rule:**** reverify federal/provincial law status and current regulator material at candidate freeze.

Chapter 01 — Purpose, scope, and source hierarchy

Define controlled federal, provincial, sector, regulator, contractual, and organization-specific source layers. Maintain applicability decisions, change watch, owners, and evidence index.

Chapter 02 — Federal and provincial applicability

Determine whether PIPEDA, a substantially similar provincial law, another provincial private-sector law, or sector-specific requirements apply to each processing activity. Record rationale and overlap handling.

Chapter 03 — Accountability

Assign accountable privacy leadership and operational control owners. Maintain policies, delegated responsibilities, management oversight, issue escalation, risk decisions, and corrective-action evidence.

Chapter 04 — Identifying purposes

Document purposes before or at collection and link them to systems, data categories, notices, consent or other authority, recipients, retention, and downstream uses.

Chapter 05 — Consent governance

Determine the appropriate form and validity of consent based on sensitivity, expectations, context, risk, and applicable law. Maintain capture, withdrawal, exceptions, and evidence.

Chapter 06 — Limiting collection

Collect only personal information appropriate to documented purposes and applicable authority. Govern optional fields, telemetry, inferred data, enrichment, and secondary collection sources.

Chapter 07 — Limiting use, disclosure, and retention

Restrict use/disclosure to documented purposes or applicable exceptions and retain information only as justified by legal, regulatory, contractual, records, litigation, and business requirements.

Chapter 08 — Accuracy

Maintain proportionate data-quality controls based on use and decision impact. Provide correction paths, source-validation controls, propagation of updates, and exception evidence.

Chapter 09 — Safeguards

Apply administrative, technical, and physical safeguards proportionate to sensitivity, quantity, format, threat, access model, and harm. Maintain security design and test evidence.

Chapter 10 — Openness and transparency

Make privacy practices, responsible contacts, rights routes, major processing purposes, cross-border handling, complaint paths, and relevant choices accessible and understandable.

Chapter 11 — Individual access and correction

Operate controlled request intake, identity/authority checks, search, exemptions, response, correction, secure delivery, timing, escalation, and closure evidence.

Chapter 12 — Challenging compliance

Maintain complaint intake, investigation, response, corrective action, escalation, regulator interaction, trend analysis, and evidence preservation.

Chapter 13 — Data inventory and flow mapping

Inventory systems, repositories, vendors, interfaces, transfers, data categories, processing purposes, locations, owners, access paths, and retention dependencies.

Chapter 14 — Processor and vendor governance

Assess service providers for purpose, access, safeguards, subcontractors, location, breach support, retention, deletion, oversight, audit, and exit requirements. Maintain contracts and monitoring.

Chapter 15 — Cross-border processing

Document cross-border storage, access, support, disclosures, legal exposure, contracts, transparency, risk controls, and applicable federal/provincial requirements without implying that cross-border processing is categorically prohibited or unrestricted.

Chapter 16 — Breach risk assessment

Use a documented method to evaluate security incidents involving personal information, including sensitivity, probability of misuse, affected individuals, safeguards, exposure, and applicable legal thresholds.

Chapter 17 — Breach reporting and notification

Determine regulator and individual notification requirements under the applicable law and facts. Maintain decision evidence, timing, content, communications, third-party coordination, and remediation.

Chapter 18 — Breach recordkeeping

Maintain required breach records and supporting analysis for the applicable retention period and regulator expectations, with access controls and linkage to incident evidence.

Chapter 19 — Employee information

Assess employee and applicant information separately by jurisdiction, organization type, and activity. Maintain workforce notices, access, security, monitoring, retention, rights, and vendor controls.

Chapter 20 — Children and youth

Apply age-, capacity-, sensitivity-, service-, and risk-appropriate transparency, consent/authority, minimization, design, advertising, profiling, and safeguarding controls based on applicable law and regulator expectations.

Chapter 21 — Biometrics

Identify biometric collection, inference, matching, authentication, monitoring, or identification use cases. Document authority, necessity, proportionality, security, retention, access, deletion, vendor, and provincial overlays.

Chapter 22 — Marketing and analytics

Govern marketing, tracking, profiling, analytics, audience creation, consent/choice, suppression, data sharing, and related communications under applicable privacy and anti-spam/electronic-marketing requirements.

Chapter 23 — Cloud and SaaS

Map responsibilities for cloud/SaaS processing, administrative access, location, telemetry, backups, subprocessors, incident support, deletion, portability, security settings, and exit.

Chapter 24 — AI and automated processing

Inventory automated and AI-supported processing involving personal information. Assess purpose, consent/authority, data quality, minimization, transparency, inference risk, human oversight, security, vendor, and provincial requirements.

Chapter 25 — Rights-request operations

Maintain standardized intake, routing, identity/authority, search, legal review, response, secure delivery, correction, complaint, metrics, and evidence workflows across applicable jurisdictions.

Chapter 26 — Provincial overlays

Maintain separate controlled overlays for applicable provincial private-sector, health, public-sector, employment, biometrics, consumer, and sector obligations. Do not merge provincial duties into federal PIPEDA requirements.

Chapter 27 — Retention and disposal

Define retention schedules, legal holds, archival, deletion, anonymization where appropriate, media sanitization, vendor deletion, exceptions, and disposal evidence.

Chapter 28 — Training and competence

Deliver role-based privacy/security training for data handlers, rights teams, HR, marketing, engineering, procurement, security, executives, and incident personnel. Maintain competency evidence.

Chapter 29 — Assurance and audit

Test consent, purposes, notices, requests, safeguards, vendors, cross-border processing, breaches, retention, marketing, biometrics, and AI using risk-based samples. Track findings to verified closure.

Chapter 30 — Metrics and management review

Track rights timeliness, complaints, breach decisions, vendor findings, consent issues, retention exceptions, training, remediation aging, provincial change watch, and regulator developments. Record management decisions.

Chapter 31 — Localization, provenance, and release evidence

Freeze EN/es-419/pt-BR candidates before final exact review. Bind DOCX/PDF identities to SHA-256 and preserve source-version, structure, parity, accessibility, render, workflow-security, and staging evidence.

Chapter 32 — Implementation roadmap and release-time reverification

Implement applicability/inventory; accountability/purposes; consent/rights; safeguards/vendors; transfers/breaches; special contexts; assurance/improvement. Immediately before publication, verify PIPEDA status, applicable provincial laws, and current regulator guidance. Publication remains sequential after Manual 41.